



Chapter 16 – Burp Suite (Web Application Penetration Testing)



Introduction to Burp Suite

◆ What is Burp Suite?

Burp Suite is one of the most popular web application penetration testing tools used by:



Ethical Hackers



Penetration Testers



Security Analysts



Bug Bounty Hunters

It helps security professionals identify vulnerabilities in web applications before attackers can exploit them.



Why Do Companies Use Burp Suite?

When a website or web application is developed, it may contain security weaknesses such as:

- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- Authentication Bypass
- Session Hijacking
- Weak Session IDs
- Insecure Cookies
- Brute Force Vulnerabilities
- Business Logic Flaws

Before releasing the application to customers, security teams test it using Burp Suite.

✚ Simple Real-Life Example

Imagine a bank creates a new online banking website.

Before customers use it, security engineers test:

- ✓ Can someone bypass login?
- ✓ Can passwords be stolen?
- ✓ Can session cookies be hijacked?
- ✓ Can money transfer requests be modified?

Burp Suite helps answer these questions.

◆ How Burp Suite Works

Burp Suite works as a **Proxy Server** between:

Client (Browser)



Burp Suite



Web Server

Instead of your browser directly communicating with the website:

Browser → Website

It becomes:

Browser → Burp Suite → Website

What Happens?

- 1 User requests a webpage.
- 2 Request goes to Burp Suite first.
- 3 Burp Suite captures the request.
- 4 Tester can inspect or modify it.
- 5 Burp sends request to server.
- 6 Server responds.

- 7 Response again passes through Burp.
 - 8 Tester can inspect the response.
-

Why Is This Useful?

Because now we can see:

- ✓ Username
- ✓ Passwords being submitted
- ✓ Cookies
- ✓ Session Tokens
- ✓ Headers
- ✓ Request Parameters
- ✓ API Calls
- ✓ Hidden Values

and test whether they are secure.



Understanding HTTP and HTTPS

◆ HTTP (HyperText Transfer Protocol)

HTTP is the protocol used to transfer data between:

- Browser (Client)
- Web Server

Default Port

80

Characteristics

- Data is transmitted in plain text.
- Not encrypted.
- Easy to intercept.

Example

When you visit:

`http://example.com`

Your browser sends:

`GET / HTTP/1.1`

`Host: example.com`

Server responds with webpage data.

HTTPS (HyperText Transfer Protocol Secure)

HTTPS is the secure version of HTTP.

It uses:

SSL/TLS Encryption

This protects:

- Passwords
 - Banking Data
 - Credit Card Information
 - Session Tokens
-

Default Port

443

Example

`https://amazon.com`

Data is encrypted before transmission.

✦ Difference Between HTTP and HTTPS

Feature	HTTP	HTTPS
Encryption	✗ No	✓ Yes
Security	Low	High
Port	80	443
SSL/TLS	✗	✓
Safe for Login Pages	✗	✓

◆ HTTP Request and Response

Web communication works using:

1 Request

Sent by browser to server.

Example:

GET /index.html HTTP/1.1

Host: example.com

2 Response

Sent by server back to browser.

Example:

HTTP/1.1 200 OK

<html>

Welcome

</html>

◆ Common HTTP Methods

Method	Purpose	Example
GET	Retrieve data	Open webpage
POST	Send data	Login Form
PUT	Update data	Update profile
DELETE	Delete data	Delete account

📌 GET Method Example

`https://example.com/profile?id=10`

Used for fetching data.

📌 POST Method Example

Submitting:

Username

Password

Comment

Feedback

Data is sent inside request body.

🔍 Browser Developer Tools

Developer Tools help inspect:

- Requests
- Responses
- Cookies
- Headers
- Network Activity

Opening Developer Tools

Method 1

Browser Menu:

Three Dots



More Tools



Developer Tools

Method 2 (Shortcut)

CTRL + SHIFT + I

Network Tab

The Network tab shows all communication between browser and server.



Important HTTP Headers

Accept

Tells server which response formats are accepted.

Example:

Accept: text/html

Accept-Encoding

Specifies compression formats supported.

Examples:

gzip

deflate

br

Accept-Language

Specifies preferred language.

Example:

Accept-Language: en-US

Cache-Control

Controls how long content stays cached.

Example:

Cache-Control: max-age=3600

Cookie Header

Contains:

- Session IDs
- Authentication Tokens
- User Preferences

Example:

Cookie: PHPSESSID=ABCD1234

 If attackers steal valid session cookies, they may impersonate users.

Date Header

Shows date and time of response.

◆ Referrer Policy

Controls what information is shared when moving from one website to another.

Common Referrer Policies

Policy	Description
no-referrer	Sends no referrer
no-referrer-when-downgrade	HTTPS → HTTPS only
origin	Sends only domain
origin-when-cross-origin	Full same-site, domain cross-site
same-origin	Only within same site
strict-origin-when-cross-origin	Most secure and common
unsafe-url	Sends full URL always

Recommended Policy

✅ strict-origin-when-cross-origin

Because it reduces information leakage.

◆ Permission Policy

Defines browser permissions granted to websites.

Examples:

-  Microphone
-  Camera
-  Screen Capture
-  Location



HTTP Response Status Codes

100–199 Informational

Request received.

200–299 Success

Examples

200 OK

Request successful.

201 Created

New resource created.

300–399 Redirection

Examples

301 Moved Permanently

Permanent redirect.

302 Found

Temporary redirect.

304 Not Modified

Use cached content.

400–499 Client Errors

Examples

400 Bad Request

Invalid request syntax.

401 Unauthorized

Login required.

403 Forbidden

Access denied.

404 Not Found

Page doesn't exist.

405 Method Not Allowed

Method not supported.

408 Request Timeout

Request took too long.

500–599 Server Errors

Examples

500 Internal Server Error

Application error.

502 Bad Gateway

Invalid response from backend server.

503 Service Unavailable

Server overloaded.

504 Gateway Timeout

Backend server did not respond.



Starting Burp Suite in Kali Linux

Run:

```
sudo burpsuite
```



Configure Browser Proxy

Go to:

Settings



Search Proxy



Manual Proxy Configuration

Enter:

Address: 127.0.0.1

Port: 8080

◆ What is 127.0.0.1?

This is called:

Loopback Address

It refers to your own machine.

Traffic never leaves your computer.

Used for:

- Testing
 - Development
 - Local Services
-

Configure Same Proxy in Burp Suite

Inside Burp:

Proxy



Options



127.0.0.1

Port 8080



Intercept Feature

Go to:

Proxy



Intercept



Intercept ON

How Intercept Works

Step 1

Open login page.

Step 2

Enable Intercept.

Step 3

Enter credentials.

Step 4

Click Login.

Step 5

Burp captures request before server receives it.

Step 6

Modify request if needed.

Step 7

Forward request manually.

◆ Repeater

Purpose

Manual request testing.

Allows repeated modification and sending of requests.

Example

Captured Login Request:

POST /login

Send to Repeater.

Try:

admin

administrator

test

guest

Observe responses.

Response Analysis

Response	Meaning
200 OK	Success
302 Redirect	Possible login success
Invalid Credentials	Failed login

◆ Intruder

Purpose

Automated testing of inputs.

Used for:

- Password Testing
- Parameter Testing
- Username Enumeration
- Fuzzing

Steps to Use Intruder

1

Capture request.

2

Send to Intruder.

3

Click Clear.

4

Select fields.

5

Click Add.

6

Choose attack type.

7

Load payload list.

8

Start Attack.

Types of Intruder Attacks

1 Sniper

Uses one payload list.

Tests one parameter at a time.

Example

Known username.

Testing only passwords.

2 Battering Ram

Same payload inserted everywhere.

Example

Testing:

admin

admin

in multiple fields.

3 Pitchfork

Multiple payload lists run together.

Example

user1 → pass1

user2 → pass2

Cluster Bomb

Tests all combinations.

Example

3 usernames

×

100 passwords

Produces:

300 combinations

Most powerful but slowest.



Understanding Intruder Results

Burp shows:

- Status Code
- Response Length

Example:

Attempt	Length
----------------	---------------

Wrong Password	126
----------------	-----

Wrong Password	126
----------------	-----

Correct Password	228
------------------	-----

Different length often indicates success.



Wordlists

A wordlist is a file containing possible usernames or passwords.

Manual Wordlist Example

admin
root
guest
password
123456

Using Crunch

Generate custom wordlists:

```
crunch 4 6 abcdef123 > wordlist.txt
```

Creates combinations of length 4–6.

Using CeWL

Generate words from website content:

```
cewl https://example.com -w wordlist.txt
```

Pre-Built Wordlists

Most common:

`/usr/share/wordlists/rockyou.txt`

Contains millions of passwords.

◆ Sequencer

Purpose

Tests randomness of session IDs.

What is Session ID?

Unique token generated after login.

Example:

SessionID=AB12CD34EF56

Used to identify users.

Why Test Session IDs?

Weak session IDs can be guessed.

This may lead to:

- ✗ Session Hijacking
 - ✗ Account Takeover
-

Using Sequencer

Step 1

Capture request with Session ID.

Step 2

Send to Sequencer.

Step 3

Start Live Capture.

Step 4

Collect many tokens.

Step 5

Analyze Now.

Entropy (Randomness)

Entropy measures unpredictability.

Session ID Strength

Randomness	Security
------------	----------

Less than 100 bits	Weak
--------------------	------

128 bits or more	Strong
------------------	--------

Save Tokens Feature

Burp can export all captured session IDs.

Useful for:

- Further analysis
 - Statistical testing
 - Reporting
-

Practical Uses of Burp Suite

Burp Suite is commonly used to test:

- ✓ Login Forms
- ✓ Registration Pages
- ✓ Password Reset Functionality
- ✓ Cookies
- ✓ Session Management
- ✓ APIs

- ✓ File Upload Features
- ✓ Authentication Mechanisms

Burp Suite Tools Summary

Tool	Purpose
Proxy	Capture traffic
Intercept	Stop and modify requests
Repeater	Manual testing
Intruder	Automated testing
Sequencer	Session randomness testing
Decoder	Encode/Decode data
Comparer	Compare requests/responses
Extender	Add plugins/extensions

Important Notes

- ✓ Burp Suite is primarily used by security professionals and companies before launching applications.
- ✓ It acts as a proxy between browser and server.
- ✓ It allows inspection and modification of HTTP/HTTPS requests and responses.
- ✓ Repeater is used for manual testing.
- ✓ Intruder automates payload testing.
- ✓ Sequencer evaluates session token strength.
- ✓ Weak session IDs can lead to session hijacking.

✓ Always perform testing only on systems you own or are authorized to assess.

Chapter 16 Quick Summary

Topic	Key Point
-------	-----------

Burp Suite	Web Application Security Testing Tool
------------	---------------------------------------

Proxy	Intercepts browser traffic
-------	----------------------------

HTTP	Port 80
------	---------

HTTPS	Port 443
-------	----------

Intercept	Captures requests
-----------	-------------------

Repeater	Manual request testing
----------	------------------------

Intruder	Automated payload testing
----------	---------------------------

Sequencer	Session token randomness analysis
-----------	-----------------------------------

Wordlists	Used for testing inputs
-----------	-------------------------

Session ID	Identifies logged-in users
------------	----------------------------

Entropy	Measures randomness/security
---------	------------------------------

 **Real-World Example:** Before a banking website goes live, security teams use Burp Suite to test login pages, session management, password reset features, cookies, and APIs to ensure attackers cannot exploit vulnerabilities and compromise customer accounts.